

System and Network Security

Dr. Ashok Kumar Das

IEEE Senior Member
Professor

Center for Security, Theory and Algorithmic Research
International Institute of Information Technology, Hyderabad

E-mail: *ashok.das@iiit.ac.in*

Homepage: <http://www.iiit.ac.in/people/faculty/ashok-kumar-das>

Personal Homepage: <https://sites.google.com/view/iitkgpakdas/>

Authentication Applications: X.509 AUTHENTICATION SERVICE

- ITU-T (International Telecommunication Union-Telecommunication Standardization Sector) recommendation X.509 is part of the X.500 series of recommendations that define a directory service.
- The directory is a server or a distributed set of servers that maintains a database of information about users.
- X.509 is an important standard because the certificate structure and authentication protocols defined in X.509 are used in a variety contexts, such as X.509 certificate format is used in
 - ▶ **S/MIME (Secure Multipurpose Internet Mail Extension)** for providing E-mail security.
 - ▶ **IPSec (IP security)** for providing the Network Layer security.
 - ▶ **SSL/TLS (Secure Socket Layer/Transport Layer Security)** for providing security at the Transport Layer.
 - ▶ **SET (Secure Electronic Transaction)** for providing Application Layer Security (for examples, Credit card/Debit card transactions).

Characteristics of X.509 (Continued...)

- X.509 is based on the use of public-key cryptography and digital signatures.
- The heart of X.509 scheme is the public-key certificate associated with each user.
- Each certificate contains the public-key of a user and is signed with the private key of a trusted certification authority (CA).
- The user certificates are assumed to be created by some trusted certification authority (CA) and placed in the directory by the CA or by the user.

General Format of a X.509 Certificate

Table: X.509 Certificate Formats

Version (1/2/3) (V)
Certificate serial number (SN)
Signature algorithm identifier (AI)
Issuer name (CA)
Period of validity (T_A)
Subject (user) name (A)
Subject's public-key info (A_p)
Issuer unique identifier (V2 and V3 only)
Subject (user) unique identifier (V2 and V3 only)
Extensions (V3 only)
Signature on the above fields (all versions)

- **Version:** Differentiates among successive versions of the certificate format: the default version is V1. If the issuer unique identifier or subject unique identifier are present, then it is V2. If one or more extensions are present, the version must be V3.
- **Serial Number:** An integer value, unique within issuing CA.
- **Signature Algorithm Identifier:** The algorithm used to sign the certificate, together with associated parameters.
- **Issuer Name:** X.500 name of the CA that created and signed this certificate.
- **Period of Validity:** Consists of two dates: the first and last on which the certificate is valid.

- **Subject Name:** The name of the user to whom this certificate refers. That is, this certificate certifies the public key of the subject who holds the corresponding private key.
- **Issuer Unique Identifier:** An optional bit string field used to identify uniquely the issuing CA in the event the X.500 name has been reused for different entities.
- **Subject Unique Identifier:** An optional bit string field used to identify uniquely the subject in the event the X.500 name has been reused for different entities.
- **Extensions:** A set of one or more extension fields. Extensions are added in V3.
- **Signature:** Covers all of the other fields of the certificate; it contains the hash code (H) of the other fields, encrypted with CA's private key. This field includes the signature algorithm identifier.

- The standard uses the following notation to define a certificate (for V1):
 $CA \ll A \gg = CA\{V, SN, AI, CA, T_A, A, A_p, sgnData\}$
- $CA \ll A \gg$ = the certificate of user A issued by the certification authority CA.
- $sgnData$ = signature of the information
 $I = \{V, SN, AI, CA, T_A, A, A_p\}$.
- Thus, $sgnData = E_{KR_{ca}}[H(V||SN||AI||CA||T_A||A||A_p)]$,
where KR_{ca} : private key of CA; KU_{ca} : public key of CA.

- Sometimes it may be desirable to revoke a certificate before it expires due to the following reasons:
 - ▶ The user's private key (KR) is assumed to be compromised.
 - ▶ The user is no longer certified by this CA.
 - ▶ The CA's certificate is assumed to be compromised.

Table: Certificate Revocation List (CRL)

	Signature Algorithm Identifier (AI)
	Issuer Name (CA)
	This update date
	Next update date
Revoked Certificate ⇒	User certificate Serial # Revocation date
	⋮
Revoked Certificate ⇒	User certificate Serial # Revocation date
	Signature on the above fields

Certificate Authentication

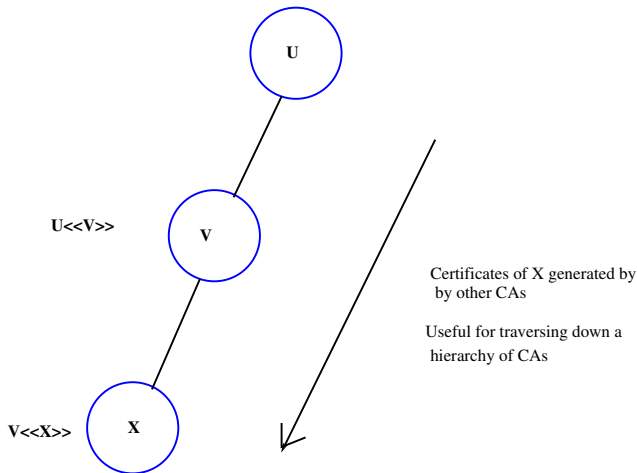


Figure: Forward certificates example

Certificate Authentication (Continued...)

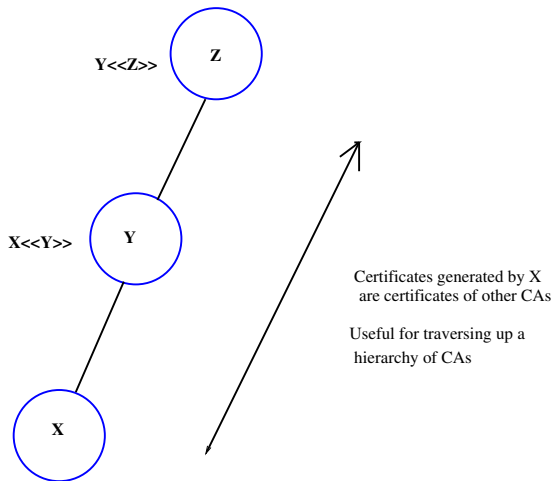


Figure: Reverse certificates example

Problem: Suppose that user A has a digital certificate from certification authority X_1 and user B has obtained a certificate from CA X_2 .

Present a hypothetical scenario where user A can verify the certificate of user B .

- **Case I:** If A does not know securely the public-key of X_2 , the B 's certificate issued by X_2 is useless to A , because the certificate needs to be decrypted using KU_{X_2} , the public-key of X_2 . A can read the certificate, but can not verify the signature.

- **Case II:** If two CAs have securely exchanged their own public keys, then the following procedure will enable A to obtain B 's public key:
 - ▶ **Step 1.** A obtains the certificate of X_2 signed by X_1 from the directory. Because A securely knows the X_1 's public key, A can obtain X_2 's public-key from its certificate and verify it by means of X_1 's signature on the signature.
 - ▶ **Step 2.** A then goes back to the directory and obtains the certificate of B signed by X_2 . Because A knows now a trusted copy of X_2 's public-key, A can verify the signature and securely obtain B 's public-key. Hence, A verifies the certificate of B .

Note: Here, A has used a chain of certificates to obtain B 's public key. In the notation of X.509, this chain is expressed as:

$X_1 \ll X_2 \gg X_2 \ll B \gg$.

In a similar fashion, B can also obtain A 's public-key with the reverse chain: $X_2 \ll X_1 \gg X_1 \ll A \gg$.

Generalization of this scheme

- The above scheme need not to be limited to a chain of two certificates.
 - ▶ An arbitrarily long path of CAs can be followed to produce a chain.
 - ▶ A chain with N elements could be expressed as:
$$X_1 \ll X_2 \gg X_2 \ll X_3 \gg \dots X_N \ll B \gg$$
 - ▶ A can use the chain to verify the certificate of B issued by CA, X_N .

Certificate Authentication (Continued...)

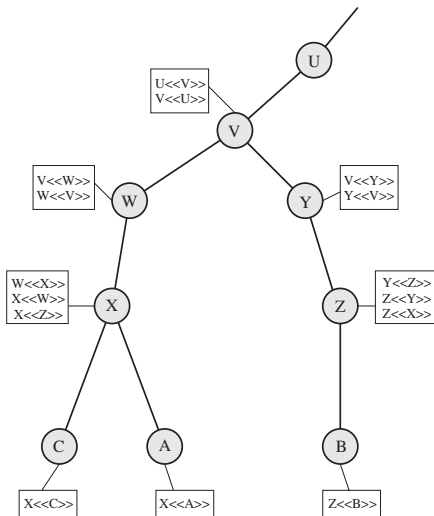


Figure: X.509 Hierarchy: A Hypothetical Example

One-way Authentication

It involves a single transfer of information from one user (A) to another (B), and establishes the following.

- 1 The identity of A and that the message was generated by A .
 - 2 That message was intended for B .
 - 3 The integrity and originality (it has not been sent multiple times) of the message.
- $A \rightarrow B : \langle t_A, r_A, ID_B, sgnData, E_{K_{U_b}}(K_{ab}) \rangle$
 t_A : timestamp prevents delayed delivery of messages,
 r_A : random nonce used to detect replay attacks. B stores the nonce until it expires and reject any new messages with the same nonce,
 ID_B : identity of B , $sgnData = E_{K_{R_a}}[t_A || r_A || ID_B]$, signature on data containing t_A , r_A , and ID_B .
 K_{ab} : secret symmetric session key between A and B .

Authentication Procedures (Continued...)

One-way Authentication (Continued...)

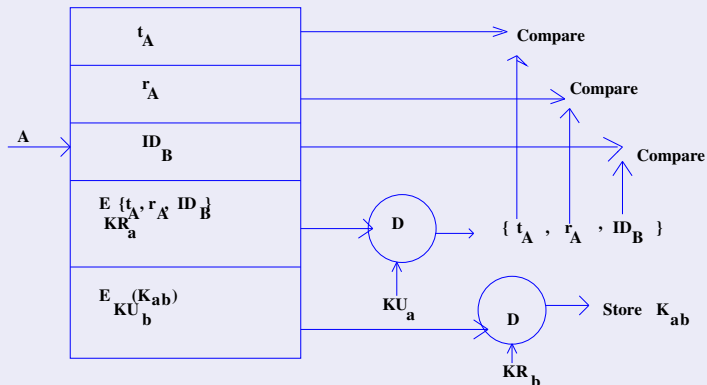


Figure: Verification of signature by B

Two-way Authentication

It involves transfer of two messages between one user (A) to another (B), and establishes the following:

- 1 The identity of A and that the message was generated by A .
- 2 That message was intended for B .
- 3 The integrity and originality (it has not been sent multiple times) of the message.
- 4 The identity of B and that the replay message was generated by B .
- 5 That the message was intended for A .
- 6 The integrity and originality of the replay.

Two-way Authentication (Continued...)

- $A \rightarrow B : \langle t_A, r_A, ID_B, sgnData_1, E_{KU_b}[K_{ab}] \rangle$ (Already in One-way Authentication)
- $B \rightarrow A : \langle t_B, r_B, ID_A, sgnData_2, E_{KU_a}[K_{ba}] \rangle$ (Added in Two-way Authentication)

where

$$\begin{aligned} K_{ab} &= K_{ba} \\ sgnData_1 &= E_{KR_a}[t_A || r_A || ID_B], \\ sgnData_2 &= E_{KR_b}[t_B || r_B || ID_A || r_A] \end{aligned}$$

Authentication Procedures (Continued...)

Three-way Authentication (X.509 Strong Authentication Procedure)

- Involves exchanges of three messages between A and B
- Final message from A to B is included, which is a signed copy of the nonce r_B .
- $A \rightarrow B : \langle t_A, r_A, ID_B, sgnData_1, E_{K_{U_b}}[K_{ab}] \rangle$ (Already in One-way Authentication)
- $B \rightarrow A : \langle t_B, r_B, ID_A, r_A, sgnData_2, E_{K_{U_a}}[K_{ba}] \rangle$ (Already in Two-way Authentication)
- $A \rightarrow B : \langle r_B \rangle$ (Added in Three-way Authentication)
 where

$$\begin{aligned}
 K_{ab} &= K_{ba} \\
 sgnData_1 &= E_{K_{R_a}}[t_A || r_A || ID_B], \\
 sgnData_2 &= E_{K_{R_b}}[t_B || r_B || ID_A || r_A]
 \end{aligned}$$

Thank You